

Gobierno, permisos y proyectos

Plan de ampliación para roles jerárquicos, permisos granulares, alta de usuarios y colaboración mediante proyectos.

Semana 3

Documento de planificación retrospectiva

Base funcional: estructura actual del proyecto

SECCIÓN 01

Visión de gobierno y colaboración

La tercera iteración separa gobierno, análisis y operación. Se incorpora el analista como responsable del ciclo de datos e insights, mientras el administrador obtiene control central de identidades y permisos. Los proyectos introducen espacios colaborativos con membresías e invitaciones.

Resultado de la semana: Admin gobierna usuarios y permisos; Analista carga datasets, genera y publica insights; Trabajador consume insights y opera módulos autorizados; todos colaboran en proyectos según su membresía.

Objetivos

Eje	Objetivo verificable
Roles globales	Agregar analyst y retirar al admin del trabajo analítico cotidiano.
Permisos	Configurar ver, crear, editar y eliminar por usuario y módulo.
Identidades	Crear cuentas desde el panel sin acceso manual a la base de datos.
Proyectos	Crear espacios, seleccionar uno activo y asociar datasets.
Colaboración	Invitar por correo, aceptar/rechazar y gestionar miembros/roles.
Defensa en profundidad	Reproducir las reglas de interfaz mediante RLS y función segura.

Principios de diseño

- Mínimo privilegio: toda capacidad comienza denegada y se habilita explícitamente.
- Separar rol global (admin, analyst, worker) de rol dentro del proyecto (owner, admin, editor, viewer).
- No exponer service_role al navegador; las operaciones administrativas sensibles viven en backend.
- Conservar compatibilidad con datasets e insights creados en semanas anteriores.

SECCIÓN 02

Modelo de autorización objetivo

Rol global	Responsabilidad principal	Base de acceso
Administrador	Gobierno total: usuarios, roles, permisos y supervisión.	Acceso completo por is_admin().
Analista	Carga y depuración de datasets; generación, revisión y publicación de insights.	Permisos explícitos sobre insights/datos.
Trabajador	Consulta de insights publicados y operación del mini CRM.	Permisos explícitos asignados.

Matriz de permisos configurables

Módulo	Acciones controladas	Valor inicial sugerido para no admin
Dashboard	view, create, update, delete	Solo view.
Clientes / Ventas / Productos	view, create, update, delete	View + create + update.
Envíos / Actividades	view, create, update, delete	View + create + update.
Insights	view, create, update, delete	Según rol: analyst completo; worker view.
Documentación	view, create, update, delete	Solo view o según asignación.

- Activar create, update o delete activa también view.
- Desactivar view desactiva las demás acciones del módulo.
- El administrador no requiere filas de permisos: su acceso se resuelve globalmente.
- Las rutas, menús y botones consultan can(módulo, acción); las tablas aplican has_permission().

SECCIÓN 03

Administración de usuarios

Flujo de alta

01 Admin abre formulario	02 Captura nombre/correo/clave/rol	03 Edge Function valida sesión	04 Auth crea cuenta	05 Triggers crean perfil y permisos
-----------------------------	--	-----------------------------------	------------------------	--

Capa	Control requerido
Formulario	Nombre obligatorio, email válido, contraseña temporal mínima de 8 caracteres y rol permitido.
Edge Function	Aceptar POST, CORS, validar JWT, consultar profiles y exigir role = admin.
Servicio privilegiado	Usar SUPABASE_SERVICE_ROLE_KEY únicamente dentro de la función.
Supabase Auth	Crear usuario confirmado con metadata de nombre y rol.
Trigger de perfil	Copiar identidad a profiles; sembrar permisos iniciales para no admins.
Interfaz	Agregar al listado, mostrar confirmación y permitir ajuste inmediato de permisos.

Criterios de seguridad

- Nunca incluir la clave de servicio en variables VITE_* ni en código del cliente.
- No confiar en user_metadata para conceder administración; verificar el rol persistido en profiles.
- Traducir duplicados y errores de validación sin filtrar detalles internos.
- Registrar actor, fecha y resultado de altas y cambios de rol en una futura bitácora de auditoría.

SECCIÓN 04

Sistema de proyectos e invitaciones

Rol de proyecto	Capacidades
owner	Control total; configura, gestiona miembros, edita datasets y elimina proyecto.
admin	Gestiona miembros e invitaciones; edita datasets; no elimina el proyecto.
editor	Trabaja con datasets del proyecto; no gestiona miembros.
viewer	Acceso de lectura al proyecto y sus datasets.

Ciclo de invitación

01 Owner/admin invita email	02 Invitación pendiente	03 Usuario la ve en Proyectos	04 Aceptar o rechazar	05 Membresía activa
--------------------------------	----------------------------	----------------------------------	--------------------------	------------------------

- Una invitación es única por proyecto y correo; reenviar actualiza rol y fecha.
- Aceptar elimina la invitación pendiente y crea o actualiza project_members.
- Rechazar elimina la invitación de la bandeja del usuario.
- El propietario puede cambiar descripción, roles, quitar miembros, cancelar invitaciones y eliminar el proyecto.
- El proyecto activo se conserva en almacenamiento local y filtra el explorador de datasets.

SECCIÓN 05

Arquitectura y modelo de datos ampliado

01 Auth + profiles	02 Permisos globales	03 Contexto de proyecto	04 Membresía / RLS	05 Datasets e insights
-----------------------	-------------------------	----------------------------	-----------------------	---------------------------

Entidad / función	Responsabilidad y relación
profiles	Rol global validado: admin, analyst o worker.
user_permissions	PK compuesta user_id + module; cuatro banderas de acción.
is_admin()	Consulta segura del perfil autenticado y concede acceso global.
has_permission(module, action)	Resuelve admin o permiso explícito; se reutiliza en RLS.
projects	Nombre, descripción, owner_id y fecha.
project_members	Membresía única por usuario/proyecto y rol local.
project_invites	Correo, rol propuesto, emisor, fecha y estado pendiente.
datasets.project_id	Asociación opcional; datasets históricos pueden permanecer sin proyecto.
create-user	Frontera de backend para Supabase Auth Admin API.

Capas del frontend

- AuthContext mantiene usuario global, rol, permisos y función can().
- ProjectContext carga proyectos, proyecto activo y capacidades derivadas del rol local.
- Servicios encapsulan Supabase: datasetStorage, ailnsights, projectStorage y documentación.
- AppRoutes protege sesiones, administración y módulos; Sidebar filtra navegación.
- Páginas de proyectos separan bandeja de invitaciones, listado y configuración.

SECCIÓN 06

Plan de entrega por incrementos

Incremento	Trabajo planificado	Aceptación
A. Roles	Añadir analyst, normalizar perfiles y adaptar navegación.	Tres roles inician sesión con menú correcto.
B. Permisos	Crear tabla, helpers, RLS y matriz administrativa.	Cambios aplican sin nueva versión del cliente.
C. Alta	Crear Edge Function y formulario de usuario.	Admin crea cuenta; no admin recibe 403.
D. Proyectos	Esquema, servicios, contexto, selector y creación.	Proyecto activo persiste y filtra datasets.
E. Invitaciones	Enviar, listar, aceptar, rechazar y cancelar.	Invitado obtiene acceso solo al aceptar.
F. Gobierno	Roles locales, remoción, borrado y pruebas RLS.	Matriz global/local validada extremo a extremo.

Migración y compatibilidad

- Validar que existan tablas requeridas, roles compatibles y al menos un administrador antes de aplicar cambios.
- Crear permisos iniciales conservadores para usuarios existentes y disparador para perfiles nuevos.
- Mantener project_id nullable para no bloquear datasets históricos.
- Reemplazar políticas globales anteriores por políticas granulares de forma atómica.
- Desplegar create-user y probarla antes de habilitar el botón en producción.

SECCIÓN 07

Pruebas de aceptación y seguridad

Área	Escenarios obligatorios
Usuarios	Alta válida, email duplicado, clave corta, rol inválido, token ausente y solicitante no admin.
Permisos	Dependencia de view, reversión ante error, acceso directo por URL y llamadas manuales a tablas.
Analista	Carga dataset, genera borrador, publica y no administra usuarios salvo permiso expreso.
Trabajador	Ve solo publicados; cada módulo responde a su matriz individual.
Proyectos	Crear, seleccionar, editar, eliminar; aislamiento entre miembros y no miembros.
Invitaciones	Duplicada, correo normalizado, aceptar, rechazar, cancelar y cambio de rol.
RLS	Owner/admin/editor/viewer ejecutan exactamente las operaciones previstas.
Regresión	Carga CSV, reportes, mini CRM e insights de semanas anteriores siguen funcionando.

Amenazas a comprobar

- Escalada por metadata, role = admin o uso de create-user sin JWT válido.
- Acceso a proyecto ajeno cambiando el UUID o consulta de contenido sin view.
- Cambio o eliminación del owner por parte de otro miembro.

SECCIÓN 08

Riesgos, operación y definición de terminado

Riesgo	Mitigación / seguimiento
Confusión de roles	Distinguir rol global y de proyecto en UI y documentación.
RLS / permisos	Pruebas con usuarios reales, helpers mínimos y sembrado transaccional.
Invitación pendiente	Conservar por correo y vincular al iniciar sesión.
Operación privilegiada	Edge Function, secreto de servidor, verificación y auditoría.

Despliegue

01 Respaldo	02 Aplicar migraciones	03 Desplegar Edge Function	04 Pruebas smoke por rol	05 Habilitar UI
----------------	---------------------------	-------------------------------	-----------------------------	--------------------

Definición de terminado

- Admin crea usuarios y modifica roles/permisos sin entrar a la base de datos.
- Analyst gestiona datasets e insights; worker consume publicados y módulos concedidos.
- Invitaciones generan membresía solo tras aceptación y los datasets quedan aislados por proyecto.
- Migraciones, función, variables, pruebas y recuperación están documentados.

Cierre de la etapa: el producto pasa de una aplicación con roles fijos a una plataforma gobernada por permisos y espacios colaborativos, manteniendo trazabilidad sobre datos, análisis y acceso.